HACKCHAIN SECURITY REVIEW

Protocol Architecture & Interaction Guide / Guía de Arquitectura e Interacción

AS-IS Foundry contract topology, trust boundaries, asset flows, and recommended target architecture

Auditor / Auditor:
Julian Ruiz
Blockchain Engineer - Smart Contract Security Reviewer
linkedin.com/in/julian-ruiz-v

Document / Documento:
Architecture Guide / Guía de Arquitectura
Audited commit / Commit auditado:
290377e9862aeabaa2814bcd0bac9ddad2707ce8
Date / Fecha:
11 July 2026 / 11 de julio de 2026

Document purpose / Propósito

ES

Alcance

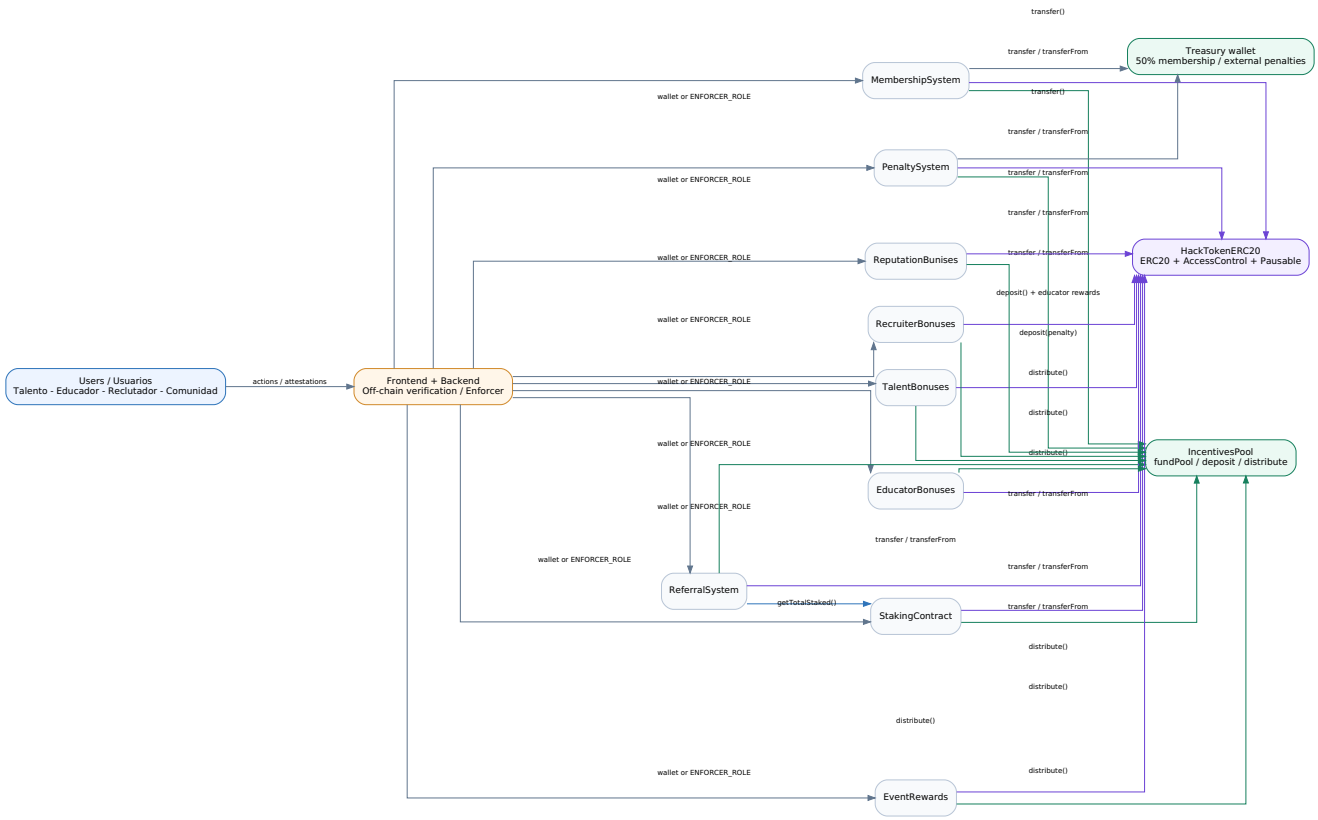
Esta guía describe lo que existe en el snapshot Foundry auditado. Los nombres de contratos y funciones son reales. Cuando se presenta una arquitectura objetivo, se marca explícitamente como TO-BE / recomendada.

EN

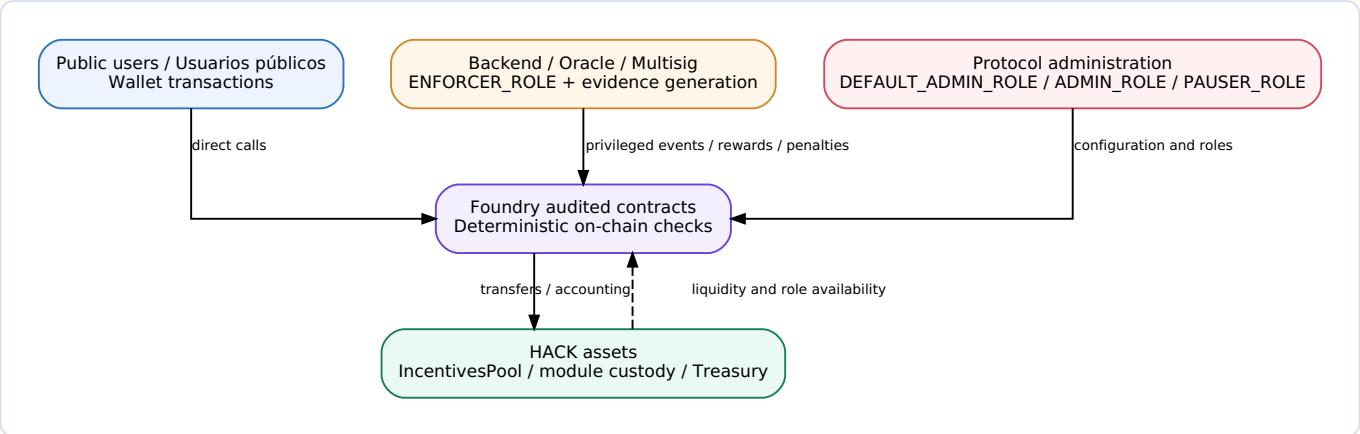
Scope

This guide describes the audited Foundry snapshot as it exists. Contract and function names are real. Any target architecture is explicitly labeled TO-BE / recommended.

AS-IS contract topology / Topología actual



Trust boundaries / Límites de confianza



Primary trust assumption / Supuesto principal: Many rewards and penalties originate from off-chain facts submitted by ENFORCER_ROLE. The contracts therefore need signed evidence, unique identifiers, replay protection, multisig administration, and observable configuration changes.

Contract catalog / Catálogo de contratos

Contract	Responsibility / Responsabilidad	Main functions / Funciones
`HackTokenERC20.sol`	ERC-20 supply, burn, pause, Ownable + AccessControl	`mintTokens, burn, pause, unpause, transferOwnershipCustom`
`IncentivesPool.sol`	Reward custody and accounting	`fundPool, deposit, distribute, actualBalance`
`StakingContract.sol`	One-month/one-year staking and fee exemption	`stake, unstake, activateNoCommission`
`ReferralSystem.sol`	Referral registration and reward validation	`registerReferral, validateReferral`
`MembershipSystem.sol`	Advanced and academic memberships; educator view pool	`activateAdvancedMembership, activateAcademicMembership, registerContentView, claimEducatorRewards`
`PenaltySystem.sol`	Identity, sale, no-show, inactivity and plagiarism penalties	`applyIdentityFraudPenalty, applyMassSalePenalty, applyNoShowPenalty, applyPlagiarismPenalty`
`EventRewards.sol`	Promotional, attendance, first-event and monthly-event rewards	`rewardPromoEvent, registerTalentAttendance, claimTalentAttendanceReward, registerEducatorEvent`
`EducatorBonuses.sol`	API, legacy certificates, active talents and hiring bonuses	`rewardApiIntegration, registerLegacyCert, claimFirstTalentsBonus, rewardTalentHired`
`TalentBonuses.sol`	Degree, hiring and open-source project funding	`rewardSchoolingDegree, rewardTalentHired, fundProject, distributeToTalents`
`RecruiterBonuses.sol`	Registration, monthly hiring and KYC bonuses	`registerRecruiter, claimRegistrationBonus, registerHiring, verifyKyc, claimKycBonus`
`ReputationBunises.sol`	Monthly reputation winners	`registerWinner, claimBonus, returnUnclaimedBonus`

Role model / Modelo de roles

Role	Current use / Uso actual	Recommended holder / Titular recomendado
DEFAULT_ADMIN_ROLE	Grants and revokes protocol roles.	Delayed multisig / AccessControlDefaultAdminRules.
ADMIN_ROLE	Updates pool, treasury, and dependency addresses.	Multisig + timelock + emitted configuration events.

Role	Current use / Uso actual	Recommended holder / Titular recomendado
ENFORCER_ROLE	Submits off-chain facts, rewards, and penalties.	Backend signer quorum or oracle/multisig; never a single hot EOA.
DISTRIBUTOR_ROLE	Allows modules to pay from IncentivesPool.	Only audited modules with per-module budgets.
DEPOSITOR_ROLE	Notifies accounting deposits.	Only modules that perform atomic safeTransferFrom + measured accounting.
PAUSER_ROLE / EMERGENCY_ROLE	Global token pause today.	Emergency multisig; module-level entrance pauses with exits preserved.

Flujo de staking y recompensa / Staking and reward flow



ES

Riesgo principal

La salida del principal y el pago de recompensa están acoplados. Además, la exención de comisión no exige madurez real.

EN

Primary risk

Principal release and reward payment are coupled. Fee exemption also does not require actual maturity.

Flujo de referidos / Referral flow



ES

Riesgo principal

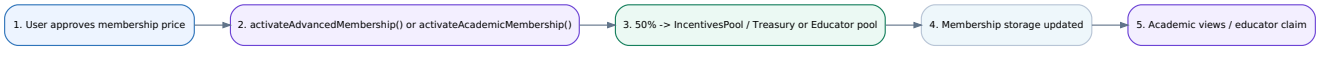
validateReferral() usa el total agregado del stake y no vincula una posición madura ni una identidad única.

EN

Primary risk

validateReferral() uses aggregate stake and does not bind a matured position or unique identity.

Flujo de membresías y pool de educadores / Membership and educator-pool flow



ES

Riesgo principal

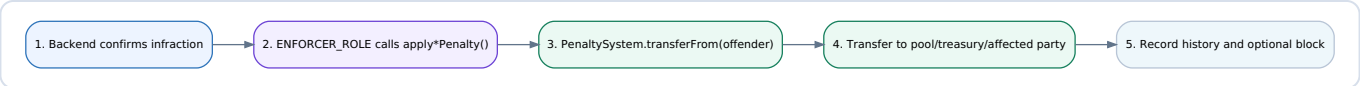
Las vistas son auto-reportadas y repetibles; algunos transfer() no usan SafeERC20.

EN

Primary risk

Views are self-reported and replayable; some transfer() calls do not use SafeERC20.

Flujo de penalizaciones / Penalty flow



ES

Riesgo principal

La sanción depende de allowance voluntario y de un balance mutable leído después del hecho.

EN

Primary risk

Enforcement depends on voluntary allowance and a movable balance read after the event.

Flujo de bonos off-chain / Off-chain bonus flow



ES

Riesgo principal

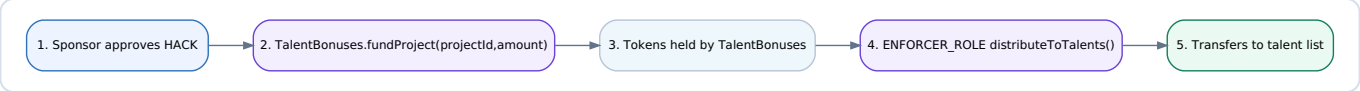
Los eventos off-chain no siempre tienen IDs canónicos, firma ni protección de replay.

EN

Primary risk

Off-chain facts do not consistently carry canonical IDs, signatures, or replay protection.

Flujo de financiación de proyectos / Open-source project funding flow



ES

Riesgo principal

El sponsor puede sobrescribirse y no existe deadline/reembolso para fondos no distribuidos.

EN

Primary risk

Sponsor attribution can be overwritten and undistributed funds have no deadline/refund path.

Recommended target architecture / Arquitectura objetivo recomendada

Core design rules / Reglas centrales

1. **Evidence-first:** every off-chain fact carries a canonical ID, EIP-712 signature, nonce, deadline, chainId, and verifying contract.
2. **Idempotent state:** processed[evidenceId] is set before any external payment.
3. **Principal safety:** user principal is never coupled to optional reward liquidity.
4. **Backed accounting:** poolBalance never exceeds actual HACK assets minus reserved obligations.
5. **Granular incident response:** pause entrances and privileged claims independently; preserve safe withdrawals.
6. **Single authority model:** delayed multisig administration with explicit role migration and observable changes.
7. **Bounded execution:** no unbounded transfer loops; use pagination or pull claims.

Current AS-IS	Recommended TO-BE
Aggregate stake checked for referrals.	Referral bound to a mature stake ID and unique identity/ evidence ID.
Principal and reward paid atomically.	Principal withdrawal separated from pending reward claim.
Self-reported repeatable content views.	Signed unique view attestations and closed-cycle snapshots.
Penalty transferFrom requires offender allowance.	Escrow or debt-and-freeze enforcement using immutable case snapshots.
Off-chain counters lack canonical IDs.	All event/hiring/KYC evidence is signed, unique, and replay-protected.
Global token pause freezes all transfers.	Module entrance pauses preserve principal exits.

Deployment verification checklist / Checklist de despliegue

- Verify bytecode and constructor parameters for every contract.
- Verify every ADMIN, ENFORCER, DISTRIBUTOR, DEPOSITOR, PAUSER and DEFAULT_ADMIN assignment.
- Verify no hot EOA retains default admin or mint/burn/pause authority.
- Fund and reserve IncentivesPool before enabling claims.
- Run all unit, fuzz, invariant, gas and role-matrix tests against deployment configuration.
- Rehearse pause entrances, principal withdrawal, role revocation, pool depletion and recovery on testnet.